

BÀI GIẢNG VỀ BẢO MẬT

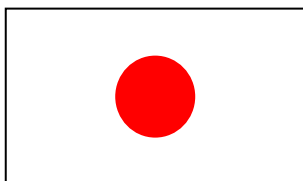
dành cho nhân viên mới

Giảng viên: Bùi Trần Lượng

GIỚI THIỆU

LUVINA SOFTWARE JSC
Ngày thành lập: 15/07/2004

Thị trường mục tiêu:



※Khách hàng hiện tại của Luvina phần lớn là khách hàng Nhật Bản, bao gồm các công ty SI lớn, các ngân hàng, công ty chứng khoán và các công ty dịch vụ mạng tại thị trường Nhật Bản.

Những khách hàng này có yêu cầu rất cao về bảo mật.

Chứng chỉ bảo mật:



Nội dung trình bày

1

Chính sách bảo mật

2

Thỏa thuận bảo mật và không tiết lộ thông tin

3

Hệ thống tài liệu và quy định an toàn thông tin của Luvina theo tiêu chuẩn ISO 27001

4

Q&A

5

Test

PHẦN 1: CHÍNH SÁCH BẢO MẬT



Mục đích:

- ❖ Phát triển hòa hợp với thị trường CNTT
- ❖ Phát triển phù hợp với tiêu chuẩn quốc tế về bảo mật
- ❖ Tất cả nhân viên công ty có cùng nhận thức, cách nghĩ cơ bản về bảo vệ tài sản thông tin

CÁC ĐẶC TÍNH BẢO MẬT

Ngăn chặn thông tin bị tiết lộ trái phép

TÍNH BẢO MẬT



Ngăn chặn hoặc phát hiện thông tin bị giả mạo (thay đổi nội dung trái phép)

TÍNH BẢO AN



Cung cấp thông tin trong khoảng thời gian hợp lý

ANH SẴN SÀNG



Theo dõi và xác định người đã xử lý thông tin

TÍNH TRÁCH NHIỆM



Đảm bảo độ tin cậy của thông tin và xử lý

TÍNH TÍN NHIỆM



Đảm bảo tính chính xác trong việc xử lý thông tin

ANH XÁC THỰC



CÁC KHOẢN MỤC QUẢN LÝ

- **Quản lý nhân sự**
- **Quản lý chính sách**
- **Quản lý vật lý**
- **Quản lý chi tiết**

CÁC BIỆN PHÁP THỰC THI

- **Biện pháp bảo mật**
- **Biện pháp khi xảy ra sự cố**
- **Biện pháp giám sát và chuẩn mực**
- **Đảm bảo sự thống nhất giữa các nhóm**
- **Biện pháp thực thi tạo tài liệu và văn bản hướng dẫn**
- **Biện pháp thúc đẩy hệ thống bảo mật**

QUẢN LÝ VỀ NHÂN SỰ

- ❖ **Đưa chính sách bảo mật vào Công ty:** Người đại diện lãnh đạo chủ động với vấn đề bảo mật và giúp đỡ toàn diện để nhân viên tuân thủ bảo mật. Người đại diện lãnh đạo gánh trách nhiệm về bảo mật và quản lý cũng như triệt để việc nhân viên trong mỗi nhóm hiểu, tuân thủ phương châm quy tắc, thủ tục về bảo mật.
- ❖ **Vai trò và trách nhiệm của GCEO:** Người đại diện lãnh đạo có vai trò và trách nhiệm làm rõ phương châm về bảo mật sẽ thực hiện, làm cho nhân viên thấm nhuần ý thức bảo mật và giúp đỡ khi cần thiết.
- ❖ **Trách nhiệm của nhân viên:** Nhân viên cần tuân thủ các chính sách và guideline đã được quyết định trong mỗi nhóm, có trách nhiệm phòng bị để không xảy ra việc thông tin bị lấy bằng những thủ đoạn bất chính, sử dụng hoặc bị sử dụng bất chính. Nhân viên khi vào Công ty phải làm theo đúng phương châm, quy chế và thủ tục của Công ty, nộp bản cam kết sẽ tuân thủ bảo mật, và khi thôi việc thì phải trả lại toàn bộ tài sản thông tin cho Công ty.

QUẢN LÝ CHÍNH SÁCH

- ❖ **Phổ biến triệť để về chính sách:**
Người đại diện lãnh đạo phải phổ biến triệť để cho nhân viên Công ty cũng như nhân viên được phái tới về chính sách.
- ❖ **Cải tiến chính sách:**
Chính sách được Ban An toàn Thông tin xem xét lại tối thiểu 1 năm 1 lần và được cập nhật sau khi nhận được phê chuẩn của Giám đốc hay người chịu trách nhiệm.
- ❖ **Quy tắc, thủ tục trong mỗi hệ thống:**
Căn cứ vào chính sách, có thể quy định thủ tục, quy tắc có khả năng thực thi phù hợp với hoàn cảnh.

❖ **Khu vực bảo mật:**

Để đề phòng sự xâm phạm bất chính và gián đoạn trong công việc, trong thiết bị hệ thống thông tin của thông tin quan trọng, chúng ta cần thiết định khu vực bảo hộ mang tính chất vật lý, quyết định người chịu trách nhiệm quản lý (ghi là người chịu trách nhiệm quản lý khu vực) rồi mới tiến hành quản lý.

❖ **Quản lý dụng cụ:**

Việc bài trí, vứt bỏ hay di chuyển thiết bị lưu trữ, xử lý thông tin cần phải được quản lý một cách thích hợp. Việc thực hiện phải theo đúng quy tắc và thủ tục. Cấp trên xác nhận, điều tra và tùy thuộc vào nội dung của sự cố có trách nhiệm thay đổi quá trình công việc.

- ❖ **Phân tích rủi ro và phương châm quản lý**

Người đại diện lãnh đạo phân tích rủi ro của tài sản thông tin dưới quyền theo định kỳ và quyết định phương châm quản lý thích hợp đối với rủi ro đó.

- ❖ **Biện pháp với phần mềm bất chính:**

Để phòng tránh việc xâm nhập của computer virus cần phải thảo luận đầy đủ về biện pháp với soft bất chính.

- ❖ **Bảo mật PC:**

Mỗi nhân viên liên quan tới sử dụng PC phải được thảo luận đầy đủ về biện pháp bảo mật.

- ❖ **Khế ước khi ủy thác bên ngoài:**

Khi ký kết khế ước ủy thác bên ngoài, phải quy định những điều khoản quan trọng về bảo mật trong khế ước với đơn vị ủy thác và thông qua việc giám sát đơn vị ủy thác đó thảo luận đầy đủ về biện pháp bảo mật. Chúng ta sẽ trở thành người quản lý gián tiếp.

- ❖ **Backup/ Recovery:**

Biện pháp đối với việc xóa, phá hỏng tài sản thông tin là nên tiến hành khôi phục theo mức độ cần thiết và phải quyết định trước thứ tự phương pháp backup.

❖ **Quản lý khi đặt hàng với bên ngoài:**

Khi đặt hàng với bên ngoài, tiêu chuẩn để chọn nơi đặt hàng là đơn vị được đặt phải có những thỏa thuận đầy đủ về bảo mật và sau khi hết đặt hàng vẫn tiếp tục giám sát biện pháp bảo mật.

❖ **Quản lý văn bản:**

Trong việc quản lý văn bản cần phải có thảo luận đầy đủ về biện pháp bảo mật.

❖ **Quản lý khi vứt bỏ:**

Khi vứt bỏ tài sản thông tin cần thảo luận đầy đủ biện pháp bảo mật như dữ liệu chắc chắn đã được xóa...

❖ **Quản lý thay đổi hệ thống thông tin:**

Khi thay đổi hệ thống thông tin cần quy định sẵn các bước quyền hạn thay đổi, gán quyền hạn, ghi chép những thay đổi... và phải thực hiện thay đổi theo những bước đó.

BIỆN PHÁP BẢO MẬT

- ❖ **Phân biệt và chứng nhận: người sử dụng hệ thống thông tin là nhân viên Luvina – những người sử dụng đã được phê chuẩn trước.**
- ❖ **Quản lý access**
- ❖ **Phát hiện xâm nhập: chức năng phát hiện xâm nhập bắt buộc phải có.**
- ❖ **Bảo mật thiết bị di động đầu cuối**
- ❖ **Internet: Tại server công khai, Luvina chỉ công khai thông tin 1 chiều.**
- ❖ **Chức năng mã hóa**
- ❖ **Quản lý ký ức trung gian**
- ❖ **Bảo mật trong phát triển hệ thống**
- ❖ **Duy trì quản lý**

BIỆN PHÁP XỬ LÝ SỰ CỐ

Báo cáo sự cố bảo mật

- ❖ Khi xảy ra sự cố liên quan đến bảo mật thông tin, nhân viên phải nhanh chóng báo cáo với cấp trên.
- ❖ Báo cáo sự cố thực hiện theo đúng quy tắc và thủ tục. Cấp trên xác nhận, điều tra và tùy thuộc vào nội dung của sự cố, có trách nhiệm thay đổi quá trình công việc.

Kế hoạch duy trì liên tục công việc

- ❖ Lấy việc đối ứng với mọi hoàn cảnh làm tiền đề, định nghĩa các phần quan trọng liên quan đến kế hoạch kinh doanh trong mỗi nghiệp vụ chủ yếu, và phải quyết định các thủ tục khi xảy ra chuyện bất thường, thủ tục backup, thủ tục khôi phục nghiệp vụ.

BIỆN PHÁP GIÁM SÁT VÀ TIÊU CHUẨN HÓA

Giám sát

- ❖ Giám đốc và đại diện lãnh đạo quy định các hạng mục, thủ tục cần kiểm tra, giám sát và truyền đạt lại cho cấp dưới. Bộ phận giám sát sẽ thực hiện giám sát chính sách.
- ❖ Tất cả các cảnh báo hệ thống (Hệ thống cảnh báo cho quản trị viên hệ thống trong trường hợp đăng nhập bằng các phương tiện trái phép, truy cập trái phép vào thông tin đối tác kinh doanh, v.v., gây ra sự cố bảo mật.) phải được theo dõi và phải được làm rõ trong quá trình kiểm tra và thanh tra.

Tiêu chuẩn hóa

- ❖ Tất cả các yêu cầu theo luật định, quy định và hợp đồng có liên quan phải được xác định rõ ràng và được lập thành văn bản cho từng hệ thống thông tin.

ĐẢM BẢO SỰ THỐNG NHẤT GIỮA CÁC NHÓM

❖ Phân biệt mức độ bảo mật của thông tin:

Tại Luvina, tùy thuộc vào mức độ bảo mật của thông tin mà chia thành các không gian lưu thông, bao gồm thông tin lưu thông giữa những người có bốn phân, thông tin lưu thông trong nhóm phát triển, thông tin lưu thông trong nhóm lãnh đạo. Thông tin bao gồm thông tin công ty liên quan đến quản lý và công nghệ của công ty, và thông tin khách hàng liên quan đến phát triển kinh doanh. Khi phân loại mức độ bảo mật của thông tin thì phải chú ý đến các yếu tố này. Ngoài ra, dựa trên mỗi phân loại thông tin, các phương pháp quản lý liên quan đến phân phối thông tin trong mỗi phân loại sẽ được xác định khi cần thiết và phải được vận dụng.

❖ Quyền sử dụng cơ sở dữ liệu và nghĩa vụ sử dụng giữa các nhóm:

Khi một nhóm sử dụng cơ sở dữ liệu thuộc quyền quản lý của một nhóm khác thì chỉ giới hạn cho người sử dụng đã nhận được sự cho phép của chủ sở hữu thông tin. Người sử dụng có nhiệm vụ tuân thủ guideline liên quan tới bảo mật do chủ sở hữu thông tin và nhóm đó quyết định.

BIỆN PHÁP THỰC THI VIỆC TẠO TÀI LIỆU HƯỚNG DẪN, QUẢN LÝ

❖ Tạo guideline và quá trình vận dụng:

Người đại diện lãnh đạo tiến hành phân tích rủi ro liên quan tới tài sản thông tin dưới quyền mình quản lý. Dựa vào kết quả phân tích này phán đoán quy mô của rủi ro và mức độ rủi ro có thể cho phép. Đồng thời làm rõ ràng và cụ thể cách giải quyết, chi phí, thể chế, quá trình đưa vào.. của biện pháp bảo mật đối với rủi ro đang tồn tại.

Trên cơ sở đó, sau khi kiểm tra so sánh biện pháp bảo mật với kết quả phân tích rủi ro, chọn biện pháp bảo mật cần thiết để đưa vào thực tế. Đồng thời, trong mỗi mục của bảng kiểm tra kèm theo, tiến hành phân tích rủi ro và quyết định phương án đối ứng. Dựa theo chính sách bảo mật của Công ty, tập hợp kết quả điều tra lại thành guideline.

Tiếp theo đưa biện pháp bảo mật đã được chọn vào. Trên cơ sở đó cho những tuyên truyền thích hợp. Sau đó thực thi giám sát định kỳ, tái diễn theo định kỳ chu kỳ quá trình cơ bản ước lượng đã được quy định trong guideline.

BIỆN PHÁP THỰC THI VIỆC TẠO TÀI LIỆU HƯỚNG DẪN, QUẢN LÝ

- ❖ **Tuân thủ quy định trong chính sách an ninh thông tin.
Khi tạo guideline ngoài việc tuân thủ các quy định trong chính sách phải cụ thể hóa từng mục trong chính sách chung.**

- 1) Cụ thể hóa những điều dưới đây:
- 2) Làm cái gì, bao giờ, như thế nào ?
- 3) Ai là người chịu trách nhiệm thực hiện?
- 4) Ai là người chịu trách nhiệm phê chuẩn?
- 5) Trong trường hợp phát sinh vấn đề không phù hợp thì sẽ xử lý như thế nào?
- 6) Những ghi chép về kết quả thực hiện sẽ được thu nhập và bảo quản như thế nào?

BIỆN PHÁP THÚC ĐẨY HỆ THỐNG BẢO MẬT

- ❖ Từ quan điểm vận hành và sử dụng tài sản thông tin, Công ty thành lập một tổ chức xúc tiến bảo mật thông tin để thực hiện chính sách, thúc đẩy phổ biến và thúc đẩy bảo mật thông tin trong toàn công ty, đồng thời duy trì và giám sát nó.
- ❖ Người đại diện lãnh đạo thiết lập bộ phận chuyên thúc đẩy phổ cập bảo mật thông tin, đưa vào những biện pháp cần thiết và duy trì quản lý.

PHẦN 2: THỎA THUẬN BẢO MẬT KHÔNG TIẾT LỘ THÔNG TIN (NDA)



THỎA THUẬN BẢO MẬT KHÔNG TIẾT LỘ THÔNG TIN (NDA)

- 1.** Người ký hợp đồng nhận thức được rằng Công ty có thể có tài liệu mật trong quá trình phát triển và Người ký hợp đồng không có quyền đối với những tài liệu đó và không có quyền đòi hỏi quyền sở hữu.
- 2.** Người ký hợp đồng nhận thức rằng việc tiết lộ bất kỳ thông tin gì liên quan đến các tài liệu của Công ty cho bên thứ ba sẽ có thể gây thiệt hại nghiêm trọng tới công việc kinh doanh của Công ty.
- 3.** Người ký hợp đồng hiểu rằng, nhờ vị trí của Công ty trong ngành công nghiệp IT (Công nghệ thông tin), Công ty nhận được một cách không chủ động nhiều ý tưởng, các định dạng, kịch bản, đề xuất, kế hoạch và các thông tin tương tự và trong những điều thu nhận được có thể tương tự hoặc giống hệt những điều được phát triển bởi Người ký hợp đồng.
- 4.** Người ký hợp đồng nhận thức Công ty có thể từ chối đánh giá giá trị của đồ vật “items” của Người ký hợp đồng trong cả trường hợp không có sự chấp thuận của Người ký hợp đồng với mỗi hay toàn bộ các điều khoản của thỏa thuận này. Người ký hợp đồng như vậy sẽ mất quyền chuyển các tài liệu trên hoặc tương tự cho người ngoài Công ty. Người ký hợp đồng nhận thức được rằng không có quan hệ bí mật hoặc ủy thác giữa Người ký hợp đồng và Công ty, và thêm vào đó hiểu rõ không hề có bất cứ quan hệ kiểu như vậy được thiết lập về việc thảo luận hay chuyển giao “items” của Người ký hợp đồng.

THỎA THUẬN BẢO MẬT KHÔNG TIẾT LỘ THÔNG TIN (NDA)

5. Việc liên quan đến tiết lộ tài liệu mật của Công ty và các thông tin liên quan là vấn đề bảo mật và điều này được Người ký hợp đồng thừa nhận chắc chắn. Người ký hợp đồng sẽ không tiết lộ thông tin mật nói trên cho người khác và sẽ lưu ý trong việc bảo vệ, giữ gìn tính bảo mật của các thông tin và khái niệm mà được nêu ra dưới đây về mặt bản chất, mục đích, mục đích sử dụng của chúng. Tất cả những thông tin như vậy được Người ký hợp đồng tự quyết định và Người ký hợp đồng đồng ý không tiết lộ cho người khác **trong thời hạn không ít hơn 10 năm** tất cả các tài liệu của Công ty bao gồm và không hạn chế đối với các thông tin sau:

- Bí mật thương mại, bí mật công nghệ hoặc các thông tin mật liên quan đến mô hình kinh doanh, các tài sản về giải pháp IT, bao gồm qui định, đồ thị bản vẽ, tiêu đề, thiết kế, bản viết tóm tắt, thương hiệu, phần mềm, công thức, số liệu thử nghiệm, số liệu thị trường, kế hoạch kinh doanh, chiến lược kinh doanh, thông tin về các nhân viên khác, thông tin đàm phán, hợp đồng, sáng chế, bản quyền, việc xin cấp thương hiệu, và việc xin cấp và đăng ký sáng chế (bao gồm cả quá trình xử lý đơn),
- Bất kỳ thông tin mật liên quan đến khách hàng, nhà thầu, người mua hàng, nhà tư vấn, người cấp bằng, đối tác liên doanh doanh, hay đại lý của Công ty.
- Người ký hợp đồng nhận thức được rằng tất cả các thông tin nêu trên thuộc quyền sở hữu của Công ty và bất kỳ thông tin nào trong đó đều là tài sản giá trị và duy nhất đối với Công ty. Tuy nhiên Người ký hợp đồng hiểu rằng các thông tin đó được chính thức công khai không nằm trong thỏa thuận này.

THỎA THUẬN BẢO MẬT KHÔNG TIẾT LỘ THÔNG TIN (NDA)

LUVINA SOFTWARE JSC

- 6.** Các điều bắt buộc đối với Người ký hợp đồng trong thỏa thuận này có giá trị đối với tất cả các quan hệ hợp đồng hiện tại và trong tương lai giữa Người ký hợp đồng và Công ty.
- 7.** Thỏa thuận này dựa trên luật pháp của nước Cộng hòa Xã hội Chủ nghĩa Việt Nam trong việc thực thi thỏa thuận và được thực thi trên toàn bộ đất nước. Hai bên trong thỏa thuận thống nhất giành riêng quyền thực thi pháp luật cho tòa án tối cao Hà Nội để giải quyết những vụ việc vượt thỏa thuận này.
- 8.** Thỏa thuận bao gồm toàn bộ sự thông hiểu giữa hai phía liên quan đến những vấn đề có thể tranh cãi. Thỏa thuận sẽ không thay đổi trừ phi có sự chấp nhận và ký kết bởi cả hai phía.
- 9.** TÍNH PHÁP LÝ CỦA BẢN DỊCH THỎA THUẬN BẢO MẬT VÀ KHÔNG TIẾT LỘ THÔNG TIN: Công ty Cổ phần phần mềm Luvina chịu trách nhiệm về việc nội dung trong bản tiếng Việt tương đương với bản tiếng Anh.

VÍ DỤ VỀ SỰ CỐ BẢO MẬT

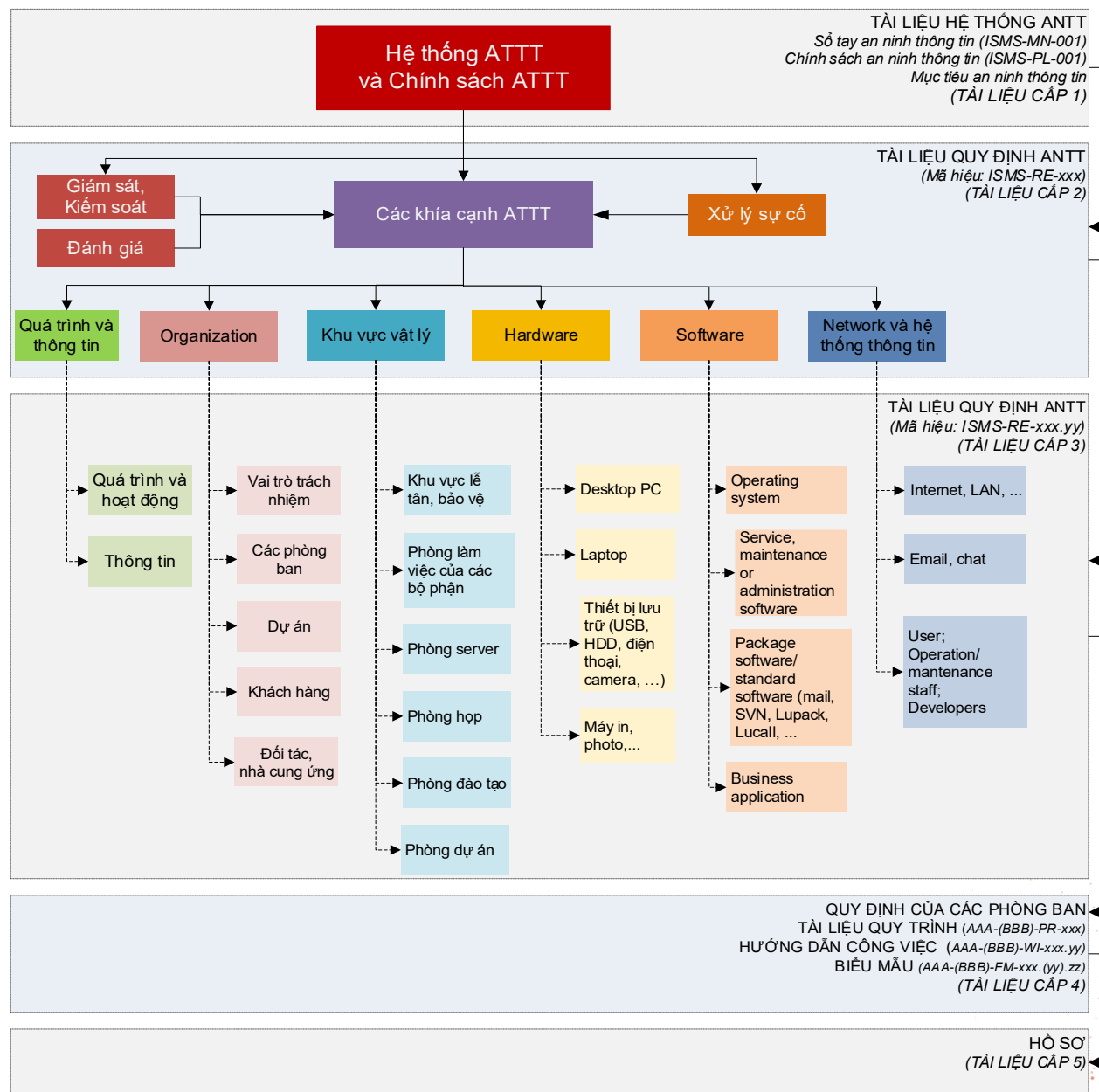
Sự cố	Hình thức kỷ luật đã áp dụng
Truy cập trái phép vào mạng nội bộ từ ngoài công ty	Phạt 1 triệu
Viết chương trình tự động login hệ thống	Cảnh cáo bằng văn bản và công bố toàn công ty
Cài đặt phần mềm vào máy tính mà không được phép	
Sử dụng account dịch vụ cloud với mục đích ngoài công việc	
Chuyển source code của công ty ra ngoài	Phạt 2 triệu và sa thải. Phạt tối đa 1.8 tỷ và truy cứu trách nhiệm hình sự nếu có thiệt hại từ các đơn kiện của khách hàng.
Sử dụng knowhow của công ty trong các công trình công bố của bản thân (luận văn, đề án ...)	Liên hệ với nhà trường để thu hồi / niêm phong tài liệu và các hình thức kỷ luật khác

PHẦN 3: HỆ THỐNG QUẢN LÝ AN TOÀN THÔNG TIN CỦA LUVINA



SƠ ĐỒ MÔ TẢ HỆ THỐNG AN NINH THÔNG TIN VÀ HỆ THỐNG TÀI LIỆU LUVINA

SƠ ĐỒ MÔ TẢ HỆ THỐNG QUẢN LÝ AN NINH THÔNG TIN (ANTT) VÀ TÀI LIỆU ANTT CỦA LUVINA



TÀI LIỆU AN NINH THÔNG TIN

url: <https://svn.luvina.net/svn/ISO/041.QuyDinhATTT>

No.	Category	Name	JP	Process Owner	Code
1	MN	Quality and Information Security Management System Manual	情報セキュリティ・品質管理システムマニュアル	ISC	LUV-MN-001
2	PO	Information Security Policy	セキュリティポリシー	ISC	LUV-ISMS-PO-001
3	PO	Personal Data Protection Policy	個人情報保護ポリシー	ISC	LUV-ISMS-PO-002
4	RE	Information Security Roles and Responsibilities Regulation	情報セキュリティマネジメントシステムに於ける役割及び責任の規程	ISC	LUV-ISMS-RE-001
5	RE	Project Information Security Regulation	各プロジェクト向けのセキュリティー規程	ISC	LUV-ISMS-RE-003.01
6	RE	Information Classification and Handling Regulation	情報処理及び分別規程	ISC	LUV-ISMS-RE-004
7	RE	Human Resource Security And Personal Information Protection Regulation	人材-個人情報安全規程	ISC	LUV-ISMS-RE-005
8	RE	Physical Security Regulation	物理的安全規程	ISC	LUV-ISMS-RE-006
9	RE	Equipment Security Regulation	設備安全規程	ISC	LUV-ISMS-RE-007
10	RE	Network Regulation	ネットワーク安全規程	ISC	LUV-ISMS-RE-008
11	RE	Electronic Mail and Communication Use Regulation	Eメール及びメディア利用規程	ISC	LUV-ISMS-RE-010
12	RE	Access Control Regulation	アクセス制御規程	ISC	LUV-ISMS-RE-012
13	RE	Username and Password Management	ユーザー名・パスワード管理規程	ISC	LUV-ISMS-RE-013
14	RE	Technical Vulnerability and Technological Gap Assessment Regulation	技術弱点評価規程	ISC	LUV-ISMS-RE-015
15	RE	Incident Reporting and Handling Regulation	事故報告・対応規程	ISC	LUV-ISMS-RE-016
16	RE	Information System Audit Control and Improvement Regulation	情報セキュリティシステムの制御・評価・向上規程	ISC	LUV-ISMS-RE-019
17	RE	Discipline Regulation	規律規程	MNG	LUV-RE-021
18	RE	Annex- Financial penalties for specific violations	別紙：特定の違反に対する罰金	ISC	LUV-RE-021

TẠI SAO PHẢI TUÂN THỦ

Ảnh hưởng của việc không tuân thủ:

- ❖ Việc không tuân thủ là hành vi phản bội kỳ vọng của các bên liên quan.
- ❖ Trong trường hợp xấu nhất, điều này có thể dẫn đến việc hủy niêm yết hoặc phá sản.
- ❖ Các sự cố bảo mật cũng được coi là hành vi không tuân thủ.



ĐỊNH NGHĨA TÀI SẢN THÔNG TIN (LUV-ISMS-RE-004)

Tài sản thông tin bao gồm tất cả thông tin thuộc sở hữu của Công ty và thông tin được thu thập hoặc ủy thác cho Công ty từ bên ngoài.

Luvina phân loại tài sản thông tin như được hiển thị trong bảng dưới đây.

Trong số thông tin trong bảng dưới đây, "Mật" và "Nội bộ" được gọi chung là Thông tin Mật.

Phân loại thông tin	Định nghĩa	Ví dụ
MẬT	Tuyệt mật/Hạn chế: Thông tin nếu bị tiết lộ hoặc rò rỉ không đúng cách, dù là bên trong hay bên ngoài công ty, đều có thể gây ảnh hưởng đáng kể đến các hoạt động của công ty.	Thông tin bí mật của khách hàng, thông tin cá nhân, v.v.
	Bảo mật: Thông tin chỉ được xử lý bởi các nhân viên có liên quan (ví dụ: thành viên nhóm dự án). Thông tin được dự đoán sẽ gây ra tác động tiêu cực hoặc thiệt hại cho công ty nếu bị rò rỉ cho những người không liên quan (bao gồm cả nhân viên công ty không có mối quan hệ kinh doanh).	Requirements documents, design documents, source codes, etc.
NỘI BỘ	Thông tin thường chỉ được xử lý trong công ty hoặc thông tin được dự đoán sẽ có tác động tiêu cực hoặc gây thiệt hại cho công ty nếu bị rò rỉ ra bên ngoài công ty.	Các chính sách, quy định, thủ tục chung
CÔNG KHAI	Thông tin đã được công khai và sẽ không gây ra bất kỳ tác động tiêu cực hoặc thiệt hại nào cho công ty ngay cả khi thông tin đó bị rò rỉ.	Thông tin đã được đăng trên website của Công ty, ...

ĐỊNH NGHĨA TÀI SẢN THÔNG TIN (LUV-ISMS-RE-004)

Nếu có bất kỳ nghi ngờ nào về việc phân loại thông tin của một tài liệu (ví dụ: tài liệu không được dán nhãn hoặc không chỉ định mức độ bảo mật), phân loại mặc định sau sẽ được áp dụng:

Phân loại mặc định cho tất cả thông tin cá nhân/nhạy cảm/dự án là “MẬT”.

Phân loại mặc định cho tất cả các thông tin khác là “NỘI BỘ”.



XỬ LÝ THÔNG TIN MẬT (LUV-ISMS-RE-004)

- ① Không in ấn, sao chép, mang ra ngoài cơ sở, hoặc gửi qua email hoặc fax mà không có sự cho phép của người phụ trách.
- ② Không để tài liệu trên bàn làm việc hoặc trong máy in, v.v.; hãy cất giữ chúng trong tủ có khóa. Giữ bàn làm việc sạch.
- ③ Khi hủy tài liệu in, hãy sử dụng máy hủy tài liệu hoặc thiết bị khác để ngăn chặn việc tái sử dụng, và khi xử lý phương tiện ghi từ/quang, hãy cắt nhỏ chúng và yêu cầu quản lý dự án xác nhận rằng chúng đã được xử lý và cắt nhỏ.
- ④ Cân nhắc phương pháp nộp hàng không sử dụng phương tiện lưu trữ ngoài.

BẢO VỆ THÔNG TIN MẬT (LUV-ISMS-RE-005)

- ① Không tiết lộ thông tin mật cho người ngoài hoặc để người ngoài xem, và chỉ giới hạn số lượng người xem ở mức tối thiểu cần thiết.
- ② Không thảo luận thông tin mật bên ngoài cơ sở, chẳng hạn như trong thang máy chung của tòa nhà, ...
- ③ Khi vận chuyển, gửi thư hoặc gửi hàng, hãy cẩn thận để tránh mất mát, trộm cắp và gửi nhầm.
- ④ Việc bạn đang tham gia vào công việc được khách hàng giao phó có thể tự nó là thông tin mật, vì vậy đừng tiết lộ thông tin này một cách bất cẩn.
- ⑤ Sau khi nghỉ việc hoặc kết thúc hợp đồng, không tiết lộ hoặc sử dụng thông tin mật đã biết được trong quá trình làm việc.

BẢO VỆ THÔNG TIN CÁ NHÂN (LUV-ISMS-RE-005)

- ① **Nếu xác định thông tin đó chứa thông tin cá nhân, vui lòng không sao chép hoặc phân phối thông tin đó mà không được phép.**
- ② **Lưu trữ thông tin ở nơi có khóa (bao gồm cả mật khẩu) và luôn khóa chặt.**
- ③ **Sau khi sử dụng, hãy xé nhỏ hoặc bỏ vào hộp đựng tài liệu mật để tránh rò rỉ. Không vứt vào thùng rác.**
- ④ **Khi gửi thông tin cá nhân qua email, hãy thực hiện các biện pháp bảo mật như mã hóa tệp và đặt mật khẩu. Mật khẩu phải được gửi bằng một phương tiện liên lạc khác (không phải email).**
- ⑤ **Không được gửi đường link vào các hệ thống của khách hàng qua các công cụ liên lạc như Teams, Slack, ...**

KIỂM SOÁT AN TOÀN VẬT LÝ (LUV-ISMS-RE-006)

- | | |
|---|--|
| ① | Đeo thẻ nhân viên (ID card) trong phạm vi Công ty |
| ② | Quét ID card khi ra vào các khu vực bị giới hạn và có bố trí cửa từ |
| ③ | Đóng cửa từ sau khi ra/vào |
| ④ | Không “đi ké” |
| ⑤ | Không cố gắng đi vào các khu vực giới hạn mà bạn không được cấp quyền ra vào.
 (“KHU VỰC GIỚI HẠN” là các khu vực có cửa từ hoặc biển cảnh báo) |
| ⑥ | Không cho mượn ID card |
| ⑦ | Trả lại ID card cho phòng ADM khi nghỉ việc |

KIỂM SOÁT AN TOÀN VẬT LÝ (LUV-ISMS-RE-006)

- ⑧ Nếu bị mất ID card, vui lòng báo cho phòng ADM. Nếu bạn đang làm việc tại nơi làm việc của khách hàng, vui lòng báo cho người phụ trách bên phía khách hàng.
- ⑨ Với khách cá nhân và người giao hàng, chỉ được phép tiếp đón ở khu vực lễ tân
- ⑩ Không chụp ảnh, ghi âm, ... trong khu vực làm việc khi chưa được phép
- ⑪ Không di chuyển thiết bị văn phòng (máy tính để bàn, máy fax, thiết bị mạng, ... trong phòng họp) mà không có sự cho phép của ADM và IT-INFRA
- ⑫ Dọn dẹp bàn làm việc và khu vực làm việc để đảm bảo các tài liệu nhạy cảm hoặc có giá trị như bản vẽ dự án, hợp đồng, v.v. được bảo quản an toàn ngoài giờ làm việc
- ⑬ Vui lòng tắt tất cả các thiết bị điện (máy tính, v.v.) trước khi rời khỏi nơi làm việc (trừ các thiết bị cần nguồn điện liên tục như server, ...)

AN TOÀN THIẾT BỊ (LUV-ISMS-RE-007)

- ① Không mang vào hoặc lấy ra thiết bị khi chưa được phép.
- ② Thực hiện các biện pháp chống trộm cho máy tính xách tay và thiết bị lưu trữ.
- ③ Khóa máy tính (Window + L) (hoặc thiết bị đã đăng nhập khác) trước khi rời khỏi nơi làm việc.
- ④ Luôn đảm bảo màn hình của tất cả các máy trạm, máy tính để bàn, máy tính xách tay, v.v. được làm sạch (tức là không để tài liệu hoặc thông tin quan trọng hoặc nhạy cảm trên màn hình).
- ⑤ Tất cả máy tính để bàn, máy tính xách tay và máy trạm phải được bảo vệ bằng mật khẩu khi không có người giám sát.
- ⑥ Không lưu trữ thông tin hoặc dữ liệu riêng tư trên các thiết bị cho mượn.
- ⑦ Không cài đặt phần mềm khi chưa được phép (vui lòng tham khảo danh sách trắng của công ty).
✖ Các phần mềm bị Luvina cấm:
 1. Phần mềm điều khiển từ xa (UltraView, TeamView, v.v.)
 2. Phần mềm chia sẻ tệp (P2P, Winny, v.v.)
 3. Phần mềm trò chơi
 4. Phần mềm quảng cáo
- ⑧ Cấm sử dụng các thiết bị lưu trữ ngoài như USB, CD, DVD, máy ảnh, điện thoại thông minh,... trừ khi được Luvina cho phép vì lý do công việc.

NETWORK & INTERNET (LUV-ISMS-RE-008)

- ① **Không kết nối thiết bị và máy tính vào mạng nội bộ của Luvina khi chưa được phép.**
- ② **Chỉ sử dụng internet và email cho mục đích công việc. Hãy cẩn thận khi truy cập internet.**
- ③ **Việc gửi thông tin liên quan đến công việc ra ngoài công ty, chẳng hạn như nhà riêng hoặc điện thoại di động, có thể bị coi là rò rỉ thông tin.**
- ④ **Không đăng tải nội dung liên quan đến công việc trên mạng xã hội hoặc các nền tảng khác, hoặc nội dung phỉ báng, bôi nhọ công ty, khách hàng, công ty đối tác hoặc nhân viên của công ty.**
- ⑤ **Không thay đổi các thiết lập liên quan đến mạng (địa chỉ IP,...) khi chưa được phép.**
- ⑥ **Không sử dụng thiết bị cá nhân để phát sóng internet trong khu vực làm việc của Công ty hoặc khu vực làm việc của Khách hàng.**
- ⑦ **Liên hệ IT-INFRA (itinfra@luvina.net) nếu gặp sự cố về mạng.**

- ① Luôn cập nhật các tệp định nghĩa của phần mềm diệt vi-rút được chỉ định.
- ② Nếu bạn phát hiện (hoặc nghi ngờ) bị nhiễm vi-rút, hãy ngay lập tức ngừng sử dụng máy tính đang nghi ngờ, ngắt kết nối máy tính khỏi mạng LAN hoặc mạng khác và báo cáo ngay cho quản lý dự án hoặc nhân viên an ninh.
- ③ Xóa email có tệp đính kèm từ người gửi không xác định vì chúng có thể bị nhiễm vi-rút.

Ngay cả khi không có tệp đính kèm, đừng nhấp vào bất kỳ địa chỉ URL nào trong nội dung email.

EMAIL (LUV-ISMS-RE-010)

- ① **Cẩn thận không mở email, liên kết hoặc tệp tin không rõ nguồn gốc.**
- ② **Trước khi gửi email, vui lòng kiểm tra địa chỉ người nhận và các tệp đính kèm ít nhất hai lần.**
- ③ **Email phải có cảnh báo bảo mật ở cuối email.**
Cảnh báo bảo mật dành riêng cho công ty:

The information in this e-mail and any attached files is **CONFIDENTIAL**. It is intended solely for the addressee, or the employee or agent responsible for delivering such materials to the addressee. If you have received this message in error please return it to the sender then delete the email and destroy any copies of it. If you are not the intended recipient, any form of reproduction, dissemination, copying, disclosure, modification, distribution and/or publication or any action taken or omitted to be taken in reliance upon this message or its attachments is prohibited and may be unlawful.

At present the integrity of e-mail across the Internet cannot be guaranteed and messages sent via this medium are potentially at risk. All liability is excluded to the extent permitted by law for any claims arising as a result of the use of this medium to transmit information by or to the LUVINA Software JSC.
- ④ **Cẩn thận khi mở tệp đính kèm trong email nhận được từ người lạ.**
Không mở tệp đính kèm khi thực hiện giao dịch email lần đầu.
Không mở tệp đính kèm không được đề cập trong nội dung email hoặc chưa được xác nhận.
- ⑤ **Luôn đặt mật khẩu cho các tệp bạn gửi qua email.**
Ngoài ra, mật khẩu nên được gửi qua phương tiện liên lạc khác ngoài email.

ACCOUNT (USERNAME AND PASSWORD) (LUVINA-ISMS-RE-013)

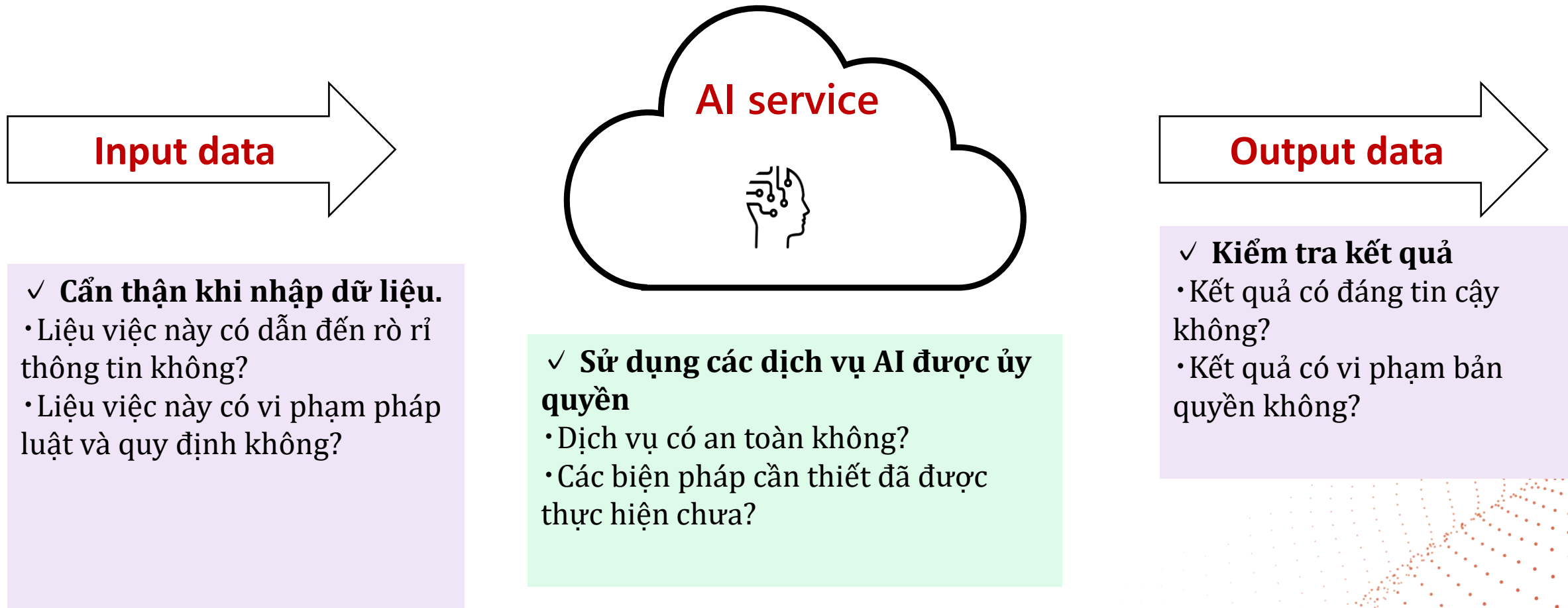
- ① **Không sử dụng tài khoản cá nhân tại nơi làm việc.
*"Tài khoản cá nhân" là tài khoản không do Công ty cung cấp.**
- ② **Hãy bảo mật và giữ bí mật tài khoản người dùng và mật khẩu của bạn.**
- ③ **Không tiết lộ hoặc cho phép người khác sử dụng tài khoản của bạn (bao gồm cả tài khoản Lucall).**

THẬN TRỌNG KHI SỬ DỤNG DỊCH VỤ AI (LUV-ISMS-WI-001)

Những điểm quan trọng khi sử dụng dịch vụ AI (nguyên tắc cơ bản):

- ① Không nhập **thông tin bí mật hoặc thông tin cá nhân** vào các dịch vụ AI
- ② Không sử dụng dữ liệu được tạo ra theo nguyên trạng (sao chép và dán), mà phải luôn chỉnh sửa và xử lý thủ công trước khi sử dụng. Ngoài ra, hãy kiểm tra các điều khoản dịch vụ.
- ③ **Sử dụng các dịch vụ AI do khách hàng cung cấp hoặc ủy quyền**

THẬN TRỌNG KHI SỬ DỤNG DỊCH VỤ AI (LUV-ISMS-WI-001)



ỨNG PHÓ VỚI SỰ CỐ BẢO MẬT (LUV-ISMS-RE-016)

- ❖ Trong trường hợp phát hiện sự cố, người phát hiện phải liên hệ ngay với người quản lý dự án (PM) hoặc trưởng phòng hoặc nhân viên an ninh của Công ty, bất kể ngày hay giờ.
- ❖ Vui lòng báo cáo ngay lập tức, ngay cả khi đó chỉ là một nghi ngờ.
- ❖ **Nhân viên an ninh:**

isc@luvina.net

lephuonganh@luvina.net - tel: 086.801.0802 (đầu mối liên lạc của Ban ATTT)

nguyendatmanh@luvina.net – tel: 097.713.2331 (đầu mối liên lạc của phòng IT-INFRA)

Q & A

TEST



Take the test at the following link:
[https://poll.luvina.net/survey/iso ob SecurityTraining](https://poll.luvina.net/survey/iso_ob_SecurityTraining)

✂ Tap the the globe icon at the top right of the screen
to select the language (VIE-JA-EN) that suits you



THANKS FOR LISTENING



4th floor – Hoa Binh tower, 106 Hoang Quoc Viet, Hanoi, Vietnam



(+84) 366 496 399



sales.en@luvina.net



www.luvina.net